

Drive-by Compromise

Adversaries may gain access to a system through a user visiting a website over the normal course of browsing. Multiple ways of delivering exploit code to a browser exist (i.e., [Drive-by Target](#)), including:

- A legitimate website is compromised, allowing adversaries to inject malicious code
- Script files served to a legitimate website from a publicly writeable cloud storage bucket are modified by an adversary
- Malicious ads are paid for and served through legitimate ad providers (i.e., [Malvertising](#))
- Built-in web application interfaces that allow user-controllable content are leveraged for the insertion of malicious scripts or iFrames (e.g., cross-site scripting)

Browser push notifications may also be abused by adversaries and leveraged for malicious code injection via [User Execution](#). By clicking "allow" on browser push notifications, users may be granting a website permission to run JavaScript code on their browser.^{[1][2][3]}

Often the website used by an adversary is one visited by a specific community, such as government, a particular industry, or a particular region, where the goal is to compromise a specific user or set of users based on a shared interest. This kind of targeted campaign is often referred to a strategic web compromise or watering hole attack. There are several known examples of this occurring.^[4]

Typical drive-by compromise process:

1. A user visits a website that is used to host the adversary controlled content.
2. Scripts automatically execute, typically searching versions of the browser and plugins for a potentially vulnerable version. The user may be required to assist in this process by enabling scripting, notifications, or active website components and ignoring warning dialog boxes.
3. Upon finding a vulnerable version, exploit code is delivered to the browser.
4. If exploitation is successful, the adversary will gain code execution on the user's system unless other protections are in place. In some cases, a second visit to the website after the initial scan is required before exploit code is delivered.

Unlike [Exploit Public-Facing Application](#), the focus of this technique is to exploit software on a client endpoint upon visiting a website. This will commonly give an adversary access to systems on the internal network instead of external systems that may be in a DMZ.

ID: T1189

Sub-techniques: No sub-techniques

ⓘ

Tactic: [Initial Access](#)

ⓘ

Platforms: Identity Provider, Linux, Windows, macOS

Contributors: Frank Angiolelli; Jeff Sakowicz, Microsoft Identity Developer Platform Services (IDPM Services); Saisha Agrawal, Microsoft Threat Intelligent Center (MSTIC)

Version: 1.7

Created: 18 April 2018

Last Modified: 24 October 2025

Procedure Examples

ID	Name	Description
C0057	3CX Supply Chain Attack	During the 3CX Supply Chain Attack , AppleJeus compromised the www.tradingtechnologies[.]com website hosting a hidden IFRAME to exploit visitors, two months before the site was known to deliver a compromised version of the X_TRADER software package. ^[5]
G0138	Andariel	Andariel has used watering hole attacks, often with zero-day exploits, to gain initial access to victims within a specific IP range. ^{[6][7]}
G0073	APT19	APT19 performed a watering hole attack on forbes.com in 2014 to compromise targets. ^[8]
G0007	APT28	APT28 has compromised targets via strategic web compromise utilizing custom exploit kits. ^[9] APT28 used reflected cross-site scripting (XSS) against government websites to redirect users to phishing webpages. ^[10]
G0050	APT32	APT32 has infected victims by tricking them into visiting compromised watering hole websites. ^{[11][12]}
G0067	APT37	APT37 has used strategic web compromises, particularly of South Korean websites, to distribute malware. The group has also used torrent file-sharing sites to more indiscriminately disseminate malware to victims. As part of their compromises, the group has used a Javascript based profiler called RICECURRENCY to profile a victim's web browser and deliver malicious code accordingly. ^{[13][14][15]}
G0082	APT38	APT38 has conducted watering holes schemes to gain initial access to victims. ^{[16][17]}
G0001	Axiom	Axiom has used watering hole attacks to gain access. ^[18]
S0606	Bad Rabbit	Bad Rabbit spread through watering holes on popular sites by injecting JavaScript into the HTML body or a .js file. ^{[19][20]}
G0060	BRONZE BUTLER	BRONZE BUTLER compromised three Japanese websites using a Flash exploit to perform watering hole attacks. ^[21]
S0482	Bundlore	Bundlore has been spread through malicious advertisements on websites. ^[22]
C0010	C0010	During C0010 , UNC3890 actors likely established a watering hole that was hosted on a login page of a legitimate Israeli shipping company that

ID	Name	Description
		was active until at least November 2021. ^[23]
G1012 CURIMUM		CURIMUM has used strategic website compromise to infect victims with malware such as IMAPLoader . ^[24]
G1034 Daggerfly		Daggerfly has used strategic website compromise for initial access against victims. ^[25]
G0070 Dark Caracal		Dark Caracal leveraged a watering hole to serve up malicious code. ^[26]
G0012 Darkhotel		Darkhotel used embedded iframes on hotel login portals to redirect selected victims to download malware. ^[27]
G0035 Dragonfly		Dragonfly has compromised targets via strategic web compromise (SWC) utilizing a custom exploit kit. ^{[28][29][30]}
G1006 Earth Lusca		Earth Lusca has performed watering hole attacks. ^[31]
G0066 Elderwood		Elderwood has delivered zero-day exploits and malware to victims by injecting malicious code into specific public Web pages visited by targets within a particular sector. ^{[32][33][34]}
S0531 Grandoreiro		Grandoreiro has used compromised websites and Google Ads to bait victims into downloading its installer. ^{[35][36]}
S0483 IcedID		IcedID has cloned legitimate websites/applications to distribute the malware. ^[37]
S0215 KARAE		KARAE was distributed through torrent file-sharing websites to South Korean victims, using a YouTube video downloader application as a lure. ^[14]
G0032 Lazarus Group		Lazarus Group delivered RATANKBA and other malicious code to victims via a compromised legitimate website. ^{[38][39]}
G0077 Leafminer		Leafminer has infected victims using watering holes. ^[40]
G0065 Leviathan		Leviathan has infected victims using watering holes. ^[41]
S0451 LoudMiner		LoudMiner is typically bundled with pirated copies of Virtual Studio Technology (VST) for Windows and macOS. ^[42]
G0095 Machete		Machete has distributed Machete through a fake blog website. ^[43]
G0059 Magic Hound		Magic Hound has conducted watering-hole attacks through media and

ID	Name	Description
		magazine websites. ^[44]
G1020	Mustard Tempest	Mustard Tempest has used drive-by downloads for initial infection, often using fake browser updates as a lure. ^{[45][46][47][48]}
C0016	Operation Dust Storm	During Operation Dust Storm , the threat actors used a watering hole attack on a popular software reseller to exploit the then-zero-day Internet Explorer vulnerability CVE-2014-0322. ^[49]
G0040	Patchwork	Patchwork has used watering holes to deliver files with exploits to initial victims. ^{[50][51]}
G0068	PLATINUM	PLATINUM has sometimes used drive-by attacks against vulnerable browser plugins. ^[52]
S0216	POORAIM	POORAIM has been delivered through compromised sites acting as watering holes. ^[14]
G0056	PROMETHIUM	PROMETHIUM has used watering hole attacks to deliver malicious versions of legitimate installers. ^[53]
S0496	REvil	REvil has infected victim machines through compromised websites and exploit kits. ^{[54][55][56][57]}
G0048	RTM	RTM has distributed its malware via the RIG and SUNDOWN exploit kits, as well as online advertising network Yandex.Direct. ^{[58][59]}
S1086	Snip3	Snip3 has been delivered to targets via downloads from malicious domains. ^[60]
S1124	SocGholish	SocGholish has been distributed through compromised websites with malicious content often masquerading as browser updates. ^[45]
G0027	Threat Group-3390	Threat Group-3390 has extensively used strategic web compromises to target victims. ^{[61][62]}
G0134	Transparent Tribe	Transparent Tribe has used websites with malicious hyperlinks and iframes to infect targeted victims with Crimson , njRAT , and other malicious tools. ^{[63][64][65]}
G0010	Turla	Turla has infected victims using watering holes. ^{[66][67]}
G0124	Windigo	Windigo has distributed Windows malware via drive-by downloads. ^[68]
G0112	Windshift	Windshift has used compromised websites to register custom URL

ID	Name	Description
		schemes on a remote system. ^[69]
G1035	Winter Vivern	Winter Vivern created dedicated web pages mimicking legitimate government websites to deliver malicious fake anti-virus software. ^[70]

Mitigations

ID	Mitigation	Description
		Browser sandboxes can be used to mitigate some of the impact of exploitation, but sandbox escapes may still exist. ^{[71][72]}
M1048	Application Isolation and Sandboxing	Other types of virtualization and application microsegmentation may also mitigate the impact of client-side exploitation. The risks of additional exploits and weaknesses in implementation may still exist for these types of systems. ^[72]
M1050	Exploit Protection	Security applications that look for behavior used during exploitation such as Windows Defender Exploit Guard (WDEG) and the Enhanced Mitigation Experience Toolkit (EMET) can be used to mitigate some exploitation behavior. ^[73] Control flow integrity checking is another way to potentially identify and stop a software exploit from occurring. ^[74] Many of these protections depend on the architecture and target application binary for compatibility.
M1021	Restrict Web-Based Content	Adblockers can help prevent malicious code served through ads from executing in the first place. Script blocking extensions can also help to prevent the execution of JavaScript.
		Consider disabling browser push notifications from certain applications and browsers. ^{[75][76][77]}
M1051	Update Software	Ensuring that all browsers and plugins are kept updated can help prevent the exploit phase of this technique. Use modern browsers with security features turned on. ^[78]
M1017	User Training	Train users to be aware of access or manipulation attempts by an adversary to reduce the risk of successful spearphishing, social engineering, and other techniques that involve user interaction.

Detection Strategy

ID	Name	Analytic ID	Analytic Description
DET0176	Drive-by Compromise — Behavior-based, Multi-platform	AN0498	Correlated evidence of anomalous browser/network behavior (suspicious external resource fetches and script injection patterns) followed by atypical child

ID	Name	Analytic ID	Analytic Description
			processes, ephemeral execution contexts, memory modification or process injection, and unexpected file drops. Defender sees network requests to previously unseen/suspicious domains or resources + browser process spawning unusual children or loading unsigned modules + file writes or registry changes shortly after those requests.
		AN0499	Correlated evidence of browser or webview fetches to uncommon domains or mutated JS resources (proxy/NGFW logs + Zeek/HTTP logs) followed by unexpected interpreters or script engines executing (python, ruby, sh) spawned from browser processes or user sessions, rapid on-disk staging in /tmp, and outbound connections that deviate from baseline. Defender sees: uncommon resource fetch → short-lived child process executions from user browser context → file writes in temp directories → anomalous outbound C2-like connections.
	Detection Strategy (T1189)	AN0500	Correlated evidence where Safari/Chrome/WebKit-based processes issue network requests for uncommon or obfuscated JS resources followed by spawning of script interpreters, launchd or ad-hoc binaries, unusual child processes, or dynamic library loads into browser processes. Defender sees: proxy/HTTP logs with suspicious resource content + unifiedlogs/ASL showing browser/plugin crashes or extension loads + process events indicating child process creation and file writes to /var/folders or /tmp shortly after the fetch.
		AN0501	Post-compromise identity & session anomalies that follow a drive-by compromise: token reuse from new/unfamiliar IPs, anomalous sign-in patterns for previously inactive users, unexpected consent/grant events, or provisioning changes. Defender sees an endpoint/browser compromise (network + endpoint signals) followed by unusual IdP events: new refresh token issuance, consent/consent-grant events, odd MFA bypass patterns, or unusual OAuth client registrations.

References

1. [Gaurav Sethi. \(2021, December 14\). The Dark Side of Web Push Notifications. Retrieved March 14, 2025.](#)

2. [Craig Schmugar. \(2021, May 17\). Scammers Impersonating Windows Defender to Push Malicious Windows Apps. Retrieved March 14, 2025.](#)
3. [Pieter Arntz. \(2019, January 22\). Browser push notifications: a feature asking to be abused. Retrieved March 14, 2025.](#)
4. [Adair, S., Moran, N. \(2012, May 15\). Cyber Espionage & Strategic Web Compromises – Trusted Websites Serving Dangerous Results. Retrieved March 13, 2018.](#)
5. [Jeff Johnson, Fred Plan, Adrian Sanchez, Renato Fontana, Jake Nicastro, Dimiter Andonov, Marius Fodoreanu, Daniel Scott. \(2023, April 20\). 3CX Software Supply Chain Compromise Initiated by a Prior Software Supply Chain Compromise; Suspected North Korean Actor Responsible. Retrieved August 25, 2025.](#)
6. [AhnLab. \(2018, June 23\). Targeted attacks by Andariel Threat Group, a subgroup of the Lazarus. Retrieved September 29, 2021.](#)
7. [Chen, Joseph. \(2018, July 16\). New Andariel Reconnaissance Tactics Uncovered. Retrieved September 29, 2021.](#)
8. [Grunzweig, J., Lee, B. \(2016, January 22\). New Attacks Linked to C0d0so0 Group. Retrieved August 2, 2018.](#)
9. [Secureworks CTU. \(2017, March 30\). IRON TWILIGHT Supports Active Measures. Retrieved February 28, 2022.](#)
10. [Billy Leonard. \(2023, April 19\). Ukraine remains Russia's biggest cyber focus in 2023. Retrieved March 1, 2024.](#)
11. [Foltýn, T. \(2018, March 13\). OceanLotus ships new backdoor using old tricks. Retrieved May 22, 2018.](#)
12. [Adair, S. and Lancaster, T. \(2020, November 6\). OceanLotus: Extending Cyber Espionage Operations Through Fake Websites. Retrieved November 20, 2020.](#)
13. [Raiu, C., and Ivanov, A. \(2016, June 17\). Operation Daybreak. Retrieved February 15, 2018.](#)
14. [FireEye. \(2018, February 20\). APT37 \(Reaper\): The Overlooked North Korean Actor. Retrieved November 17, 2024.](#)
15. [Cash, D., Grunzweig, J., Meltzer, M., Adair, S., Lancaster, T. \(2021, August 17\). North Korean APT InkySquid Infects Victims Using Browser Exploits. Retrieved September 30, 2021.](#)
16. [FireEye. \(2018, October 03\). APT38: Un-usual Suspects. Retrieved November 17, 2024.](#)
17. [DHS/CISA. \(2020, August 26\). FASTCash 2.0: North Korea's BeagleBoyz Robbing Banks. Retrieved September 29, 2021.](#)
18. [Esler, J., Lee, M., and Williams, C. \(2014, October 14\). Threat Spotlight: Group 72. Retrieved January 14, 2016.](#)
19. [M.Léveille, M-E.. \(2017, October 24\). Bad Rabbit: Not-Petya is back with improved ransomware. Retrieved January 28, 2021.](#)
20. [Mamedov, O. Sinitsyn, F. Ivanov, A.. \(2017, October 24\). Bad Rabbit ransomware. Retrieved January 28, 2021.](#)
21. [DiMaggio, J. \(2016, April 28\). Tick cyberespionage group zeros in on Japan. Retrieved July 16, 2018.](#)
22. [Sushko, O. \(2019, April 17\). macOS Bundlore: Mac Virus Bypassing macOS Security Features. Retrieved June 30, 2020.](#)
23. [Mandiant Israel Research Team. \(2022, August 17\). Suspected Iranian Actor Targeting Israeli Shipping, Healthcare, Government and Energy Sectors. Retrieved September 21, 2022.](#)

24. [PwC Threat Intelligence. \(2023, October 25\). Yellow Liderc ships its scripts and delivers IMAPLoader malware. Retrieved August 14, 2024.](#)
25. [Ahn Ho, Facundo Muñoz, & Marc-Etienne M.Léveillé. \(2024, March 7\). Evasive Panda leverages Monlam Festival to target Tibetans. Retrieved July 25, 2024.](#)
26. [Blaich, A., et al. \(2018, January 18\). Dark Caracal: Cyber-espionage at a Global Scale. Retrieved April 11, 2018.](#)
27. [Kaspersky Lab's Global Research and Analysis Team. \(2014, November\). The Darkhotel APT A Story of Unusual Hospitality. Retrieved November 12, 2014.](#)
28. [Secureworks. \(2019, July 24\). Resurgent Iron Liberty Targeting Energy Sector. Retrieved August 12, 2020.](#)
29. [US-CERT. \(2018, March 16\). Alert \(TA18-074A\): Russian Government Cyber Activity Targeting Energy and Other Critical Infrastructure Sectors. Retrieved June 6, 2018.](#)
30. [Slowik, J. \(2021, October\). THE BAFFLING BERSERK BEAR: A DECADE'S ACTIVITY TARGETING CRITICAL INFRASTRUCTURE. Retrieved December 6, 2021.](#)
31. [Chen, J., et al. \(2022\). Delving Deep: An Analysis of Earth Lusca's Operations. Retrieved July 1, 2022.](#)
32. [O'Gorman, G., and McDonald, G.. \(2012, September 6\). The Elderwood Project. Retrieved November 17, 2024.](#)
33. [Clayton, M.. \(2012, September 14\). Stealing US business secrets: Experts ID two huge cyber 'gangs' in China. Retrieved February 15, 2018.](#)
34. [Paganini, P. \(2012, September 9\). Elderwood project, who is behind Op. Aurora and ongoing attacks?. Retrieved February 13, 2018.](#)
35. [GReAT. \(2020, July 14\). The Tetrade: Brazilian banking malware goes global. Retrieved November 9, 2020.](#)
36. [Abramov, D. \(2020, April 13\). Grandoreiro Malware Now Targeting Banks in Spain. Retrieved November 12, 2020.](#)
37. [Kenefick , I. \(2022, December 23\). IcedID Botnet Distributors Abuse Google PPC to Distribute Malware. Retrieved July 24, 2024.](#)
38. [Trend Micro. \(2017, February 27\). RATANKBA: Delving into Large-scale Watering Holes against Enterprises. Retrieved May 22, 2018.](#)
39. [Weidemann, A. \(2021, January 25\). New campaign targeting security researchers. Retrieved December 20, 2021.](#)
40. [Symantec Security Response. \(2018, July 25\). Leafminer: New Espionage Campaigns Targeting Middle Eastern Regions. Retrieved August 28, 2018.](#)
41. [CISA. \(2021, July 19\). \(AA21-200A\) Joint Cybersecurity Advisory – Tactics, Techniques, and Procedures of Indicted APT40 Actors Associated with China's MSS Hainan State Security Department. Retrieved August 12, 2021.](#)
42. [Malik, M. \(2019, June 20\). LoudMiner: Cross-platform mining in cracked VST software. Retrieved May 18, 2020.](#)
43. [Kaspersky Global Research and Analysis Team. \(2014, August 20\). El Machete. Retrieved September 13, 2019.](#)
44. [ClearSky Research Team. \(2020, August 1\). The Kittens Are Back in Town 3 - Charming Kitten Campaign Evolved and Deploying Spear-Phishing link by WhatsApp. Retrieved April 21, 2021.](#)

45. [Andrew Northern. \(2022, November 22\). SocGholish, a very real threat from a very fake update. Retrieved February 13, 2024.](#)
46. [Milenkoski, A. \(2022, November 7\). SocGholish Diversifies and Expands Its Malware Staging Infrastructure to Counter Defenders. Retrieved March 22, 2024.](#)
47. [Red Canary. \(2024, March\). Red Canary 2024 Threat Detection Report: SocGholish. Retrieved March 22, 2024.](#)
48. [Secureworks. \(n.d.\). GOLD PRELUDE . Retrieved March 22, 2024.](#)
49. [Gross, J. \(2016, February 23\). Operation Dust Storm. Retrieved December 22, 2021.](#)
50. [Hamada, J.. \(2016, July 25\). Patchwork cyberespionage group expands targets from governments to wide range of industries. Retrieved August 17, 2016.](#)
51. [Meltzer, M, et al. \(2018, June 07\). Patchwork APT Group Targets US Think Tanks. Retrieved July 16, 2018.](#)
52. [Windows Defender Advanced Threat Hunting Team. \(2016, April 29\). PLATINUM: Targeted attacks in South and Southeast Asia. Retrieved February 15, 2018.](#)
53. [Tudorica, R. et al. \(2020, June 30\). StrongPity APT - Revealing Trojanized Tools, Working Hours and Infrastructure. Retrieved July 20, 2020.](#)
54. [Counter Threat Unit Research Team. \(2019, September 24\). REvil/Sodinokibi Ransomware. Retrieved August 4, 2020.](#)
55. [McAfee. \(2019, October 2\). McAfee ATR Analyzes Sodinokibi aka REvil Ransomware-as-a-Service – What The Code Tells Us. Retrieved August 4, 2020.](#)
56. [Ozarslan, S. \(2020, January 15\). A Brief History of Sodinokibi. Retrieved August 5, 2020.](#)
57. [Secureworks . \(2019, September 24\). REvil: The GandCrab Connection. Retrieved August 4, 2020.](#)
58. [Faou, M. and Boutin, J. \(2017, February\). Read The Manual: A Guide to the RTM Banking Trojan. Retrieved March 9, 2017.](#)
59. [ESET Research. \(2019, April 30\). Buhtrap backdoor and Buran ransomware distributed via major advertising platform. Retrieved May 11, 2020.](#)
60. [Jornet, A. \(2021, December 23\). Snip3, an investigation into malware. Retrieved September 19, 2023.](#)
61. [Dell SecureWorks Counter Threat Unit Threat Intelligence. \(2015, August 5\). Threat Group-3390 Targets Organizations for Cyberespionage. Retrieved August 18, 2018.](#)
62. [Legezo, D. \(2018, June 13\). LuckyMouse hits national data center to organize country-level waterholing campaign. Retrieved August 18, 2018.](#)
63. [Huss, D. \(2016, March 1\). Operation Transparent Tribe. Retrieved June 8, 2016.](#)
64. [Falcone, R. and Conant S. \(2016, March 25\). ProjectM: Link Found Between Pakistani Actor and Operation Transparent Tribe. Retrieved September 2, 2021.](#)
65. [Malhotra, A. et al. \(2021, May 13\). Transparent Tribe APT expands its Windows malware arsenal. Retrieved September 2, 2021.](#)
66. [Faou, M. \(2020, May\). From Agent.btz to ComRAT v4: A ten-year journey. Retrieved June 15, 2020.](#)
67. [Secureworks CTU. \(n.d.\). IRON HUNTER. Retrieved February 22, 2022.](#)
68. [Bilodeau, O., Bureau, M., Calvet, J., Dorais-Joncas, A., Léveillé, M., Vanheuverzwijn, B. \(2014, March 18\). Operation Windigo – the vivisection of a large Linux server-side credential-stealing malware campaign. Retrieved February 10, 2021.](#)
69. [Wardle, Patrick. \(2018, December 20\). Middle East Cyber-Espionage analyzing WindShift's implant: OSX.WindTail \(part 1\). Retrieved October 3, 2019.](#)

- 70.[CERT-UA. \(2023, February 1\). UAC-0114 aka Winter Vivern to target Ukrainian and Polish GOV entities \(CERT-UA#5909\). Retrieved July 29, 2024.](#)
- 71.[Cowan, C. \(2017, March 23\). Strengthening the Microsoft Edge Sandbox. Retrieved March 12, 2018.](#)
- 72.[Goodin, D. \(2017, March 17\). Virtual machine escape fetches \\$105,000 at Pwn2Own hacking contest - updated. Retrieved March 12, 2018.](#)
- 73.[Nunez, N. \(2017, August 9\). Moving Beyond EMET II – Windows Defender Exploit Guard. Retrieved March 12, 2018.](#)
- 74.[Wikipedia. \(2018, January 11\). Control-flow integrity. Retrieved March 12, 2018.](#)
- 75.[David Balaban. \(2022, October 7\). Remove Guroshied virus popup from Mac. Retrieved March 14, 2025.](#)
- 76.[Dan Virgillito. \(2022, January 27\). Malicious push notifications: Is that a real or fake Windows Defender update?. Retrieved March 14, 2025.](#)
- 77.[Frank Angiolelli, Indelible LLC, Malwarebytes, McAfee, Norton, Pieter Arntz, PushWelcome. \(2020, November 17\). Be Very Sparing in Allowing Site Notifications. Retrieved March 14, 2025.](#)
- 78.[Dusty Miller. \(2023, October 17\). Are You Sure Your Browser is Up to Date? The Current Landscape of Fake Browser Updates . Retrieved February 13, 2024.](#)